issued with a signed JSON Web Token that contains device details and an encrypted PSK that the API server can decrypt, as shown in listing 13.4. The device treats the certificate as an opaque token and simply presents it to APIs that it needs to access. The API trusts the JWT because it is signed by a trusted issuer, and it can then decrypt the PSK to authenticate and communicate with the device.

Listing 13.4 Encrypted PSK in a JWT claims set

```
{
    "iss":"https://example.com/devices",    #A
    "iat":1590139506,    #A
    "exp":1905672306,    #A
    "sub":"ada37d7b-e895-4d55-9571-4df602e60c27",    #A
    "psk":"
jZvara1OnqqBZrz1HtvHBCNjXvCJptEuIAAAAJInAtaLFnYna9K0WxX4_
#B
[CA]IGPyztb8VUwo0CI_UmqDQgm"    #B
}
```

#A Include the usual JWT claims identifying the device
#B Add an encrypted PSK that can be used to communicate with the device

This can be more scalable than a database if you have very many devices but makes it harder to update incorrect details or change keys. A middle ground is provided by the attestation techniques discussed in chapter 12, in which an initial certificate and key are used to prove the make and model of a device when it first registers on a network and it then negotiates a device-specific key to use from then on.